

Contract_Legal_Compliance

Technical Standard

保险公司 技术开发部
内部文档 · 仅供授权人员查阅

Contents

1. Overview
2. Technical Procurement Contract Review
 - 2.1 Common Contract Types
 - 2.2 Tech Review Checklist
 - 2.3 Review Flow
3. NDA Management
 - 3.1 Applicable Scenarios
 - 3.2 Key NDA Terms
4. Open Source Compliance
 - 4.1 License Types
 - 4.2 Management Process
 - 4.3 Insurance-Specific Notes
5. Legal Compliance Assessment Triggers

Contract & Legal Compliance Review Standard

1. Overview

This document defines procedures for technology department involvement in contract and legal compliance matters, including technical procurement contract review, technical requirement writing, NDA management, and open-source compliance. It applies to technology procurement, vendor management, and project management scenarios.

2. Technical Procurement Contract Review

2.1 Common Contract Types

Contract Type	Scenario	Tech Focus
Software Purchase	Commercial software license	License model, scope, upgrades
Software Development	Custom development outsourcing	IP ownership, acceptance criteria, source code
Cloud Services	IaaS/PaaS/SaaS	SLA, data sovereignty, export restrictions
Technology Partnership	Joint development	IP sharing, confidentiality
System Integration	Third-party integration	Interface standards, data security
Maintenance	System support	Response time, service scope, SLA metrics

2.2 Tech Review Checklist

Dimension	Check Items
Technical Requirements	Clear functional, performance, compatibility specs
Deliverables	Clear delivery list, standards, timeline
Acceptance Criteria	Feasible acceptance process and standards
Intellectual Property	Source code, documentation, data ownership
Confidentiality	Scope, duration, penalties
SLA	Response time, recovery time, availability
Penalties	Compensation for non-compliance
Data Security	Processing rights, storage location, destruction

2.3 Review Flow

Request → Tech Assessment → Legal Review → Commercial Negotiation → Signing

3. NDA Management

3.1 Applicable Scenarios

- Technical integration with third-party systems

- External development team involvement
- Vendor POC testing
- Technology proposal bidding

3.2 Key NDA Terms

Clause	Recommended Standard
Confidential Info Scope	Architecture docs, source code, data models
Duration	Contract term + 3 years post-termination
Exceptions	Public info, independent development, legal requirements
Breach Penalty	Liquidated damages + actual loss
Return/Destruction	Within 30 days of termination

4. Open Source Compliance

4.1 License Types

Type	Characteristics	Notes
Permissive (MIT, Apache 2.0, BSD)	Free use, modify, distribute	Retain copyright notice
Weak Copyleft (LGPL, MPL)	Modified lib must be open, use can be closed	Note linking method
Strong Copyleft (GPL, AGPL)	Derivative works must be open	Avoid in core systems
Business-friendly (BSL, Commons Clause)	Additional commercial restrictions	Purchase commercial license

4.2 Management Process

Introduction → License Identification → Compliance Assessment → Approval → Registration → Periodic Audit

4.3 Insurance-Specific Notes

- Avoid GPL/AGPL in core actuarial modules
- No copyleft licenses in customer data processing code
- LGPL modifications require change documentation
- Apache 2.0: pay attention to patent grant clauses

5. Legal Compliance Assessment Triggers

Scenarios requiring legal involvement:

1. New technology involving personal data processing
2. Automated decision-making (AI UW, smart claims)
3. Cross-border data transfer
4. Deep integration with external platforms

5. Tech changes affecting policy legal validity